

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (scanner CVSS-weighted) · Generated 2026-07-01 · Source SHA: `61ed8c3` · Model: `0.5·CVE + 0.3·exposure + 0.2·criticality`

Ranked remediation backlog

#	Coordinate	Ver	Band	Risk	Top CVE / issue	Fix
1	com.fastxml...:jackson-databind (typosquat)	2.9.8	CRITICAL	—	Impersonates com.fasterxml — REMOVE	remove
2	log4j-core	2.14.1	HIGH	7.8	CVE-2021-44228 Log4Shell (10.0)	2.26.0
3	jackson-databind	2.9.8	HIGH	7.8	CVE-2019-14379 (9.8) + 53 more	2.22.0
4	log4j-api	2.14.1	HIGH	6.8	CVE-2026-34479 (7.5)	2.26.0
5	mysql-connector-java	8.0.30	HIGH	6.7	CVE-2023-22102 (8.3) + GPL-2.0 license	8.0.33
6	protobuf-java	3.19.4	HIGH	6.7	CVE-2024-7254 (7.5)	3.21.7
7	guava	24.1.1-jre	HIGH	6.6	CVE-2023-2976 (7.1)	32.0.1-jre
8	jackson-annotations	2.9.0	MEDIUM	5.5	CVE-2018-1000873 (6.5)	2.9.10
9	commons-io	2.4	MEDIUM	5.2	CVE-2021-29425 (4.8)	2.14.0
10	commons-lang3	3.4	MEDIUM	5.2	CVE-2025-48924 (5.3)	3.18.0
11	jackson-core	2.9.8	LOW	2.2	no CVEs, outdated	2.19.0
12	junit-jupiter (test)	5.10.2	LOW	1.9	test-scope, outdated	6.1.1

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted
log4j-core	10.0	8.0	2.0	7.8
jackson-databind	10.0	8.0	2.0	7.8
log4j-api	8.0	8.0	2.0	6.8
mysql-connector-java	8.3	7.0	2.0	6.7
protobuf-java	9.0	6.0	2.0	6.7
guava	7.6	8.0	2.0	6.6

Note on business criticality: only `log4j-core` / `log4j-api` have a located source usage (grep hit in `DiscountCalculator.java`, an internal invoice-discount routine — scored as internal service, +2). All other dependencies default to criticality `2` (`criticality_source`: `"default"`) — no direct import was found in the small demo codebase, so criticality did not distinguish this backlog. Weight is driven almost entirely by CVE severity and exposure (direct/compile) here.

Priority recommendations

1. **P0 — Remove the typosquatted dependency.** `com.fastxml.jackson.core:jackson-databind:2.9.8` is not a real Maven Central artifact; it impersonates `com.fasterxml.jackson.core`. This is a supply-chain integrity issue independent of CVSS scoring — delete the `<dependency>` block.
2. **P0 — Upgrade log4j-core / log4j-api 2.14.1 → 2.26.0.** Log4Shell (CVE-2021-44228, CVSS 10.0, actively exploited RCE) plus 7 follow-on CVEs; directly used in production logging code.
3. **P1 — Upgrade jackson-databind 2.9.8 → 2.22.0.** 54 known CVEs spanning 2019–2023 deserialization/gadget-chain families; major-version jump, needs compatibility testing.
4. **P1 — Upgrade mysql-connector-java 8.0.30 → 8.0.33.** CVE-2023-22102 (CVSS 8.3) plus a GPL-2.0-with-FOSS-exception license-policy violation; patch-level fix, low regression risk.
5. **P1 — Upgrade protobuf-java (transitive via mysql-connector-java) → 3.21.7+** to clear CVE-2024-7254 (unbounded recursion / DoS).
6. **P1 — Upgrade guava 24.1.1-jre → 32.0.1-jre (or later stable 33.6.0-jre).** CVE-2023-2976 and CVE-2020-8908; major version, review API surface before bumping.
7. **P2 — Routine bumps:** jackson-annotations → 2.9.10, commons-io → 2.14.0, commons-lang3 → 3.18.0.
8. **P3 — Test-scope only:** junit-jupiter is outdated but LOW risk (test scope, no CVEs) — bundle into routine maintenance.

Machine-readable source: `depscan-risk-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 2.